



INTERNATIONAL TELECOMMUNICATION UNION

**TELECOMMUNICATION
STANDARDIZATION SECTOR**

STUDY PERIOD 2022-2024

SG17-TD940R2

STUDY GROUP 17

Original: English

Question(s): 14/17

Geneva, 21 February-3 March 2023

TD

Source: Editor

Title: 3rd Revised baseline text for X.sc-dlt: Security controls for distributed ledger technology

Contact: Kyeong Hee Oh
TCAServices
Korea (Republic of)
Tel: +82-502-107-0000
E-mail: khoh@tcaservices.kr

Formatted: English (United Kingdom)

Contact: Preetika Singh
Ministry of Communications,
(India)
Tel: +011-23319014
Fax: +91-9868137608
E-mail: preetika.singh87@gov.in

Formatted: English (United Kingdom)

Contact: Sandeep Ku. Vijaivergia
Ministry of Communications,
(India)
Tel: +011-23319014
Fax: +91-9982837888
E-mail: dirngn.tec@gov.in

Contact: Young Joo Lee
Sogang University
Korea (Republic of)
Tel: +82-10-9096-5820
E-mail: yjoo99@hanmail.net

Field Code Changed

Formatted: English (United Kingdom)

Abstract: This TD provides the third revised text for draft Recommendation ITU-T X.sc-dlt, Security controls for distributed ledger technology, according to Q14 meeting discussion on C261 and C305.

Draft Recommendation ITU-T X.sc-dlt

Security controls for distributed ledger technology

Summary

Distributed ledger Technologies are immutable digital ledger systems implemented in a distributed fashion (i.e. without a central repository) and usually without a central authority. There are mainly two different models through which DLT is being implemented. In addition to this, DLT has other important features which includes Smart contract, DLT Oracle etc.

Security controls varies with different implementation models of DLT along with different features such as Smart Contract etc. This recommendation mainly covers the varying security controls as per different implementation models and features of Distributed Ledger Technology.

DLT Models; Consensus Mechanism; Smart Contract ; DLT Oracle; Audit;

Draft Recommendation ITU-T X.sc-dlt

Security controls for distributed ledger technology

1 Scope

This Recommendation provides guidelines for information security best practices including the selection, implementation and management of controls on distributed ledger technologies. This Recommendation is intended to be used by organizations that would select and implement appropriate security controls for the distributed ledger technology which they run or use. Also, this recommendation can be used by organizations that would assess and evaluate security of a systems or services on distributed ledger technology.

2 References

The following ITU-T Recommendations and other references contain provisions which, through reference in this text, constitute provisions of this Recommendation. At the time of publication, the editions indicated were valid. All Recommendations and other references are subject to revision; users of this Recommendation are therefore encouraged to investigate the possibility of applying the most recent edition of the Recommendations and other references listed below. A list of the currently valid ITU-T Recommendations is regularly published. The reference to a document within this Recommendation does not give it, as a stand-alone document, the status of a Recommendation.

[ITU-T X.1400]	Recommendation ITU-T X.1400 (2020), Terms and definitions for distributed ledger technology
[ITU-T X.1401]	Recommendation ITU-T X.1401 (2019), Security threats to distributed ledger technology
[ITU-T X.1402]	Recommendation ITU-T X.1402 (2020), Security framework for distributed ledger technology.
[ITU-T F.751.2]	Reference framework for distributed ledger technologies

3 Definitions

3.1 control [b-ISO/IEC 27000]: measure that is modifying risk.

Note 1 - Controls include any process, policy, device, practice, or other actions which modify risk.

Note 2 - Controls may not always exert the intended or assumed modifying effect.

3.2 governing body (of a DLT system): a collective that makes decisions for running a DLT system

Note 1 - In a public permissionless DLT system, all participants who run a node are a member of the governing body.

3.3 consensus [b-ISO 22739]: agreement among DLT nodes that 1) a transaction is validated and 2) that the distributed ledger contains a consistent set and ordering of validated transactions

3.4 smart contract [b-ITU-T X.1400]: A program written on a distributed ledger system which encodes the rules for specific types of distributed ledger system transactions in a way that can be validated and triggered by specific conditions.

3.5 DLT platform [b-ISO 22739]: [set of processing, storage and communication entities which together provide the capabilities of the DLT system on each DLT node](#)

3.6 node [b-ITU-T X.1400]: [device or process that participates in a distributed ledger network](#)
[NOTE – A node can store a complete or partial replica of the distributed ledger](#)

3.7 on-ledger [b-ISO 22739]: [located, performed, or run inside a DLT system.](#)

3.8 off-ledger[b-ISO 22739]: related to a DLT system, but located, performed, or run outside that DLT system.

3.9 DLT system[b-ISO 22739]: a system that implements a distributed ledger

3.10 distributed ledger[b-ITU-T X.1400]: A type of ledger that is shared, replicated, and synchronized in a distributed and decentralized manner.

NOTE –blockchain is a type of distributed ledger. (See X.1400 6.8)

4 Abbreviations and acronyms

This Document uses the following abbreviations:

DLT	Distributed Ledger Technology
SDLC	Software Development Life Cycle

5 Conventions

This Recommendation applies the following verbal forms for the expression of provisions:

- a) "Shall" indicates a requirement,
- b) "Should" indicates a recommendation,
- c) "May" indicates a permission,
- d) "Can" indicates a possibility and a capability.

6 Introduction

A distributed ledger is a type of ledger that is shared, replicated, and synchronized in a distributed manner. While there are currently several different types of distributed ledgers in existence, they share certain functional characteristics: a capability of ledger network's nodes to communicate directly with each other; a mechanism for nodes on the network to propose the addition of transactions to the block and for computer programs to manage processes; and a consensus mechanism by which the distributed ledger network can validate what is the agreed-upon newly added block.

The distributed Ledger have both permissionless and permissioned governance models with varying applications and Security policies along with security requirements. Hence security controls are also varied based on its governance models along with use cases.

Different security controls are also applicable to several categories and objective also varies along with the applications.

DLT has inherent security advantage in availability and integrity, but also has vulnerability in confidentiality. These characteristics are not unchangeable but depend on its implementation and operation. To secure services based on DLT, security of DLT services need to be managed throughout its entire life cycle covering organizational aspects and technology.

The Recommendation mainly covers the different models with different security controls required for each use cases.

[Editor's Note] Editors solicit comments on the structure of this Recommendation.

7 DLT governance for security

7.1 General

DLT governance can be defined a system of directing and controlling DLT system. [Governing rules shall be established and be stated clearly to inform participants and/or users of their roles and responsibilities. Participants and users should abide by the governing rules. For fairness, the governing rules should allow interested parties to monitor the DLT systems governance as appropriate. For example, changing the governing rules or the incompliance of the DLT system to the rules shall be communicated for their own interest.](#)

DLT governance can be run ~~by a governing body for a permissioned DLT system, or by codes (on-ledger/on-chain) for a permissionless DLT system, or partially by a governing body (off-ledger/off-chain) for a permissioned DLT system.~~ The different Governance models are being categorized as Permissionless and Permissioned Model. The Choice of Governance models impacts the different security requirements and controls.

[7.2](#) ~~7.1.1~~ **Permissionless model**

Permissionless Models are decentralized platforms with no central authority and are open to participation without users requesting access. These Models often utilize a consensus method that requires more than a trivial effort in order to prevent bad users from easily subverting the system. Such consensus methods include proof of work and proof of stake methods.

Security controls to be adopted for Permissionless Model are as follows:

i. ~~Authorization Access Control:~~

~~[Editor's note] Editors soicite appropriate text for this part.~~

[Implementation of authentication and access controls enables that only valid users may access the networks.](#)

ii. Cryptographic Control:

Appropriate cryptographic controls may be implemented on use, protection and management lifecycle of keys along with controls pertaining to protection of Information.

iii. Technical Vulnerability Management:

The technical Vulnerabilities should be evaluated in a regular manner in the system and appropriate remedial mechanisms may be adopted to prevent the exposure of system for the evaluated Vulnerabilities.

[7.3](#) ~~7.1.2~~ **Permissioned model**

In this governance model user needs permission from the network administrator to become part of the DLT network. Organizations that wish to work together, but do not fully trust one another, use permissioned model and invite business partners to record their transactions on a shared distributed ledger. Although data is decentralised, administrator only defines the roles, verify identities and access within the network. These are usually being used by private businesses and private organizations.

Security controls to be adopted for permissioned model are as follows:

i. Access Control:

Adequate access control mechanism is required to ensure that only authorized user can access the System and applications. The access to the system may be provided and controlled by secure log-on procedure.

Additionally, security roles and access processes need to defined for creating, reading, deleting, updating or deactivating the data on phone.

ii. Information Classification

Although concept of DLT is based on shared ledger, however information should have adequate level of protection and appropriate set of procedures is being designed for accessing/modifying the information by the users of Blockchain

iii. Cryptographic Controls

The policy on use, protection and lifetime of cryptographic keys shall be clearly defined and implemented along with complete lifecycle.

iv. Asset Management Controls:

Guidelines to control the ownership of Hardware Tokens (signing keys) and other systems carrying the security infrastructure may be defined.

v. Physical and Environmental Security Controls:

Processes defining the key Management procedures regarding use of Hardware Security Modules along with Physical Security mechanism's such as Installation of CCTV or other gated Security Controls.

vi. Operational Security Controls

This includes the incorporation of standard Processes such as Vulnerability Assessment, Back up management, Password Management. Since Permissioned Models works on Server within the Private Network, standard processes related to security of Virtual Private Network will be applicable.

8 DLT Security policies

Control

DLT security policy should be defined and approved by the governing body. It should be complemented by appropriate levels of topic-specific security policies that are approved by appropriate management roles. The security policies should be documented and communicated to relevant parties only to the extent necessary.

Purpose

To provide the directions and support for DLT security to relevant interested parties in accordance with business requirements and applicable contractual and regulatory requirements.

Implementation guidance

DLT governing body should ~~establish~~ set its DLT security policy that is appropriate to the purpose of the DLT service it provides. The DLT security policy should ~~consider~~ address anticipated security risks and any applicable legal, regulatory, and contractual requirements.

It should include DLT security objectives, principles to guide DLT security activities, and responsibilities of defined roles and relevant parties for DLT security.

The DLT security policy should be complemented by topic-specific policies as needed. The topic-specific policies should complement and be aligned with the DLT security policy and approved by appropriate management roles in the DLT participants.

The security policies should be documented and published in an appropriate form. They should be communicated with relevant parties to the extent necessary, not to expose sensitive information. If necessary, understanding and compliance with the policies should be signed.

Other information

In some permissionless DLT systems, policies can be implemented on-ledger, and any activity of participation or use can be considered an agreement on the policies of the DLT system. However, implicit coded policies are generally difficult to read and understand, thus can mislead participants and users. This practice is not recommended from a security point of view.

9 DLT ~~node management~~platform security

DLT system implements a distributed ledger and consists of a set of nodes that interacts in the DLT network. DLT platform is a set of processing, storage and communication entities which together provide the capabilities of the DLT system on each DLT node. In a DLT system, nodes can be owned by different participants. Each participant is responsible for the security of the nodes they own.

DLT nodes should be secured in accordance with security required for servers. X.1051 can be referred for this purpose.

Especially for DLT, nodes should verify peers in communication. The routing table contains IP addresses of peer nodes should be appropriately protected. It is necessary to define rules for verifying the trustworthiness of new nodes and adding them to the routing table, review the safety of the rules, and add new nodes accordingly. In addition, the related parameters should be properly set to maintain it securely. (Number of connections, connection duration, update cycle, anomaly detection, limit on unsolicited messages, etc.)

10 DLT ~~administrator~~system management security

11 Smart contract security

A smart contract is a computer program that is deployed using cryptographically signed transactions on the distributed ledger network (e.g., Ethereum smart contracts, Hyperledger Fabric's chaincode). The smart contract is executed by nodes within the distributed ledger system. The results of the execution are validated by consensus and recorded on the distributed ledger. (X.1400) Although ~~S~~smart contract are defined as legally binding contracts, controls are required that data is stored in secure environment.

The ~~S~~security controls to be adopted for ensuring ~~S~~smart ~~C~~contract ~~S~~security are as below:

i. Secure Coding:

Code review testing may be done on code scanning, execution along ~~M~~malware scanning for ~~S~~smart ~~C~~contract. Secure SDLC practices may be followed.

If appropriate, automated review mechanism to formally validate that the code performs its desired function and is free from ~~S~~security ~~V~~vulnerabilities.

ii. Access Control Functions:

Robust access control functions may be implemented in Smart Contract Code enabling the privileges and ownership along with functionality of self-administration.

iii. Secure Oracle Networks:

Secure Oracle Networks may be used to feed the data into the Smart Contracts. While integrating with external feeds, a robust Governance process may be followed.

12 Consensus mechanism security

The consensus mechanism should be carefully selected according to the characteristics of the business solution that the underlying DLT system is trying to support. The ~~known-existing~~ and possible threats to vulnerabilities of the selected consensus mechanism should be analyzed, and countermeasures should be implemented as possible. Implementation of Security Controls in Consensus mechanisms depends on known vulnerabilities and possible threats according to

~~Consensus mechanisms ensure convergence towards a single, immutable version of the ledger. They allow actors on the network to agree on the information recorded on the blockchain, taking into consideration the fact that some actors can be untrustworthy or malicious. (X.1400)~~

Consensus mechanisms ensure convergence towards a single, immutable version of the ledger. They allow actors on the network to agree on the information recorded on the blockchain, taking into consideration the fact that some actors can be untrustworthy or malicious. (X.1400)

The Security controls to be adopted for ensuring Consensus Security are as below:

i. Authentication and Access Control:

Robust access control and authentication based processes must be implemented on the Systems so that only authorised nodes can access the System so as to prevent Consensus Based Attacks.

ii. Risk analysis and mitigation:

The business issues and requirements that could be constrained by consensus algorithms should be analyzed and documented. For example, required throughput, performance, nature and scales of informations processed by the DLT systems should be considered. Characteristics like trustworthiness of potential participants and users and verifiability of their identities also should be considered. Requirements on security, scalability and decentralization should be analyzed and specified.

The consensus mechanism should be selected or designed to meet the analyzed requirements. The consensus mechanism's safety and liveness should be ensured by analysis and test. Although formal verification is recommended, it is not always possible. Simulation is cost-effective way of test of the correctness of the consensus mechanism. However, the effectiveness of a simulation depends on how well the model reflects reality.

The basic assumptions under which the selected consensus mechanism can operate securely should be clarified. The known threats of the selected consensus mechanism should be analyzed, as well as possible theoretical threats. The vulnerabilities of the consensus mechanism itself should be identified, and of the implementation including underlying DLT system and network.

Countermeasures should be identified, selected, and implemented based on the risk resulting from the threats and vulnerabilities. The countermeasures can be technical or operational. They can include the followings but not limited to.

- Levels and methods of assurance of participants and users
- Rules for storing data on-chain and off-chain
- Security measures of off chain-data such as "world state database"
- Monitoring on resources, health of nodes and network with a list of suspicious events, i.e. communication delays, incorrect transactions etc.
- Incident management process (i.e. for DoS attack)
- Legal exception provisions

13 DLT oracle security

Oracle are third party feeds that supply smart contract with related and relevant information required by Smart Contract to execute when preconditions have been met. The information includes Exchange rate, temperature or any other event data required by individual Smart contract. It also acts as middleware for facilitating communication between DLT and off chain systems such as information from Data providers, API signatures, IoT devices, Cloud Providers etc.

The adopted Security Controls are as follows:

i. Protection from Malware:

Third Party feeds used to supply information such as Exchange rate, temperature or any other information should be free from Malware. It is to be ensured that Information and Information Processing facilities are free from Malware.

14 DLT interoperability security

15 DLT audit

The purpose of the DLT audit is to comprehensively check matters related to the development and operation of the DLT solution from a third-party perspective and minimize problems in order to secure the safety of the DLT solution. The safety of the DLT solution includes management, physical, and technical issues, not business-level issues.

DLT audit should have an environment in which third parties can audit from an independent perspective, and objective audit activities of audit may be defined in accordance with standardized audit guidelines~~should be conducted in accordance with standardized DLT audit guidelines.~~ Accordingly, governing body should develop DLT audit related regulations and DLT solution audit guidelines. DLT audit results should be improved from a management and technical perspective through corrective action activities. The scope of the DLT audit and the audit results should be documented and shared with the relevant parties.

Commented [51]: Clarify the term “objective audit activities” .Can it be changed to ‘objectives of audit may be defined in accordance with standardized audit guidelines.’

The purpose of the DLT audit is to comprehensively check matters related to the development and operation of the DLT solution from a third-party perspective and minimize problems in order to secure the safety of the DLT solution. The safety of the DLT solution includes management, physical, and technical issues, not business level issues.

Bibliography

[b-ISO/IEC 27001] ISO/IEC 27001:2022 Information Technology-Security Techniques
Information Security Management Systems -Requirements

[b-ISO 23257:2022(E)] ISO 23257:2022(E) Blockchain and distributed ledger technologies —
Reference architecture

[b-GBCT] Guidelines for Blockchain Cryptographic Technology for the Introduction of National
and Public Institutions, 2020.12;

[b-ISSN 1848-6339] ISSN 1848-6339: 2021 Technology-based Practical Blockchain Sytem Audit
Maturity Model, Youngjoo Lee, Sooyong Park

Error! No text of specified style in document.

Formatted: Font: Bold, Complex Script Font: Bold

Appendix-I

DLT Audit: process and items

(Editor's Note – The language should be revised at the next contributions)

As per defined audit objectives, Accordingly the governing body should develop DLT audit-related regulations and DLT solution audit guidelines. DLT audit results should be reviewed-improved from a management and technical perspective through corrective action activities. The scope of the DLT audit along with and the audit results should be documented and shared with the relevant parties.

The broad guidelines which can be adopted for conduction of DLT audit are as below:

i. Establishment of audit procedure:

The DLT governing body shall establish the DLT audit procedure. The DLT auditor shall develop the Audit guidelines, and supervise and manage the overall DLT audit. The DLT implementation guidelines should include instructions to audit the functionality of DLT solutions such as Smart Contract, Ledger, Interface, Network, etc. in terms of output, process, and performance. At the same time, the legal, regulatory and contractual requirements required for implementation of the system should be considered. This should include DLT audit objectives, principles guiding DLT audit activities, DLT audit procedures, defined roles in DLT audit and responsibility of the parties concerned.

The DLT audit procedure is conducted in the order of preliminary investigation, audit performance, and corrective action, and the audit time can be performed at the end of the requirement determination stage, design stage, test completion stage, and maintenance stage depending on the system life cycle.

When performing a DLT audit, the auditor shall communicate with the auditee and document and prepare a report in an appropriate format. However the sensitive information should not be exposed and communicated with the relevant parties to the extent necessary.

Audit results should be distinguished on priority basis from results that must be taken corrective action immediately and recommendations that do not need to be taken corrective action immediately.

ii. Handling the audit results:

Observations in the DLT audit report may be added or deleted. If the auditee does not have an opinion on the DLT audit report, it can be regarded as an agreement on the results of the DLT audit. Guidelines should also be prepared for cases where the auditor and the auditee disagree on the audit results. Where corrective action cannot be taken due to expenses as a result of the audit, only opinions shall be presented as recommendations.

iii. Conducting follow-up DLT audit:

Commented [52]: Define the DLT Governing body?

After the audit report is distributed, the auditor shall inspect the results of corrective action taken by the auditee for the audit results. The auditee must take legal and cost responsibility for problems arising from the auditee taking no action. The auditee shall report the results of corrective action to the audit group, and the audit group shall establish an audit plan by agreeing on the schedule with the auditee.

The auditor shall review the outcome of the corrective action taken by the auditee and give opinions on whether the results are appropriate.

The auditor shall share the action result report with the auditee and the audit client. The auditor shall share the action result report with the auditee and the audit client.

New known issues or problem during the action verification activity should be reported to the auditee and audit client without forcing additional corrective action.

iv. Audit item on DLT solution:

DLT solution is the term applied to a complete end-to-end solution that is built using a DLT system to accomplish some objectives relating to a group of organizations[b-ISO 23257:2022(E)].

The DLT solution consists of the DLT system with its DLT nodes and communication networks plus all the DLT applications connected to each of the DLT nodes, along with any associated non-DLT systems connected to the DLT system[b-ISO 23257:2022(E)].

DLT systems are classified into public DLT systems and private DLT systems depending on who can read the ledger's transaction records, and into permissionless DLT systems and permissioned DLT systems depending on whether permission is required to use the system.

The minimum basic audit items should be included to ensure that a safe system has been established, and the table below is the minimum basic audit items when building a information system on permissioned DLT type[b-GBCT] [b-ISSN 1848-6339].

Table 1 – Audit item for Permissioned DLT solutions

Classification	Audit item
<u>Password application technology</u>	<u>When using cryptographic algorithms, it is recommended to use cryptographic algorithms verified by trust agencies.</u>
<u>Account Management</u>	<u>A system should be provided to manage accounts.</u>
	<u>The object that you want to create an account with and the system that manages the account must perform mutual authentication.</u>
	<u>An object that wants to create an account must securely generate a private key and a public key pair, register the public key with the system that manages the account, and store the private key securely.</u>
	<u>The private and public key pairs in the account must be replaceable.</u>
	<u>Accounts should be retireable, and retired accounts should not be available immediately upon disposal.</u>
<u>data transmission Security</u>	<u>Objects that want to exchange data with objects in the blockchain system must perform mutual authentication.</u>
	<u>All data transmitted from the blockchain solution must be secured.</u>
<u>Consensus Protocol</u>	<u>Consensus protocols that meet the safety and liveness characteristics (failure acceptance, processing speed, etc.) required for the service environment to be provided should be used.</u>
<u>Ledger</u>	<u>Transactions should include identifiers and electronic signatures of all objects involved in the transaction's creation process, and data to prevent retransmission attacks.</u>
	<u>The object that creates the block must verify the permissions and electronic signatures of the object that participated in creating the transaction to be included in the block.</u>
	<u>The block header should contain the hash value of the previous block.</u>
	<u>The block should include the identifier, electronic signature, and generation time of the object that created the block.</u>
	<u>Personal information should not be stored or Pseudonymised information. Pseudonymised information is also included in personal information.</u>
<u>Smart Contract</u>	<u>The execution results of smart contracts should be verifiable.</u>
	<u>Smart contracts should not have known source code security vulnerabilities.</u>
	<u>When a smart contract error is detected, a replaceable plan should be established and version management of the smart contract should be performed</u>

Formatted: Centered

Formatted: Border: Bottom: (Single solid line, Auto, 1.5 pt Line width, From text: 31 pt Border spacing:)

Error! No text of specified style in document.

==

=====